



HACKYEAH 2026 · GOLDMAN SACHS · AI CONTROL LAYER

Aegis

Local-first guardrails for every agent call

Redact locally · Govern centrally · Prove continuously

allow

log

redact

require_approval

block

THE PROBLEM

Agents leak, loop and overreach

Every agent call is a data-egress event, an execution event and a spend event at the same time.

Leak

Prompts, files and tool results carry PESELs, IBANs, card numbers and secrets to remote models and third-party MCP servers.

EchoLeak (CVE-2025-32711): zero-click exfiltration via a markdown image

Get hijacked

A poisoned README, web page or MCP tool description redirects the agent (OWASP ASI01).

MCP tool poisoning · postmark-mcp
BCC backdoor

Loop

One runaway agent burns tokens or local GPU time; framework step limits are per framework, not per organization (LLM06:2026).

Overreach

Agents buy, write to production or email externally with no human approval (LLM03:2026). And nobody can prove what happened.

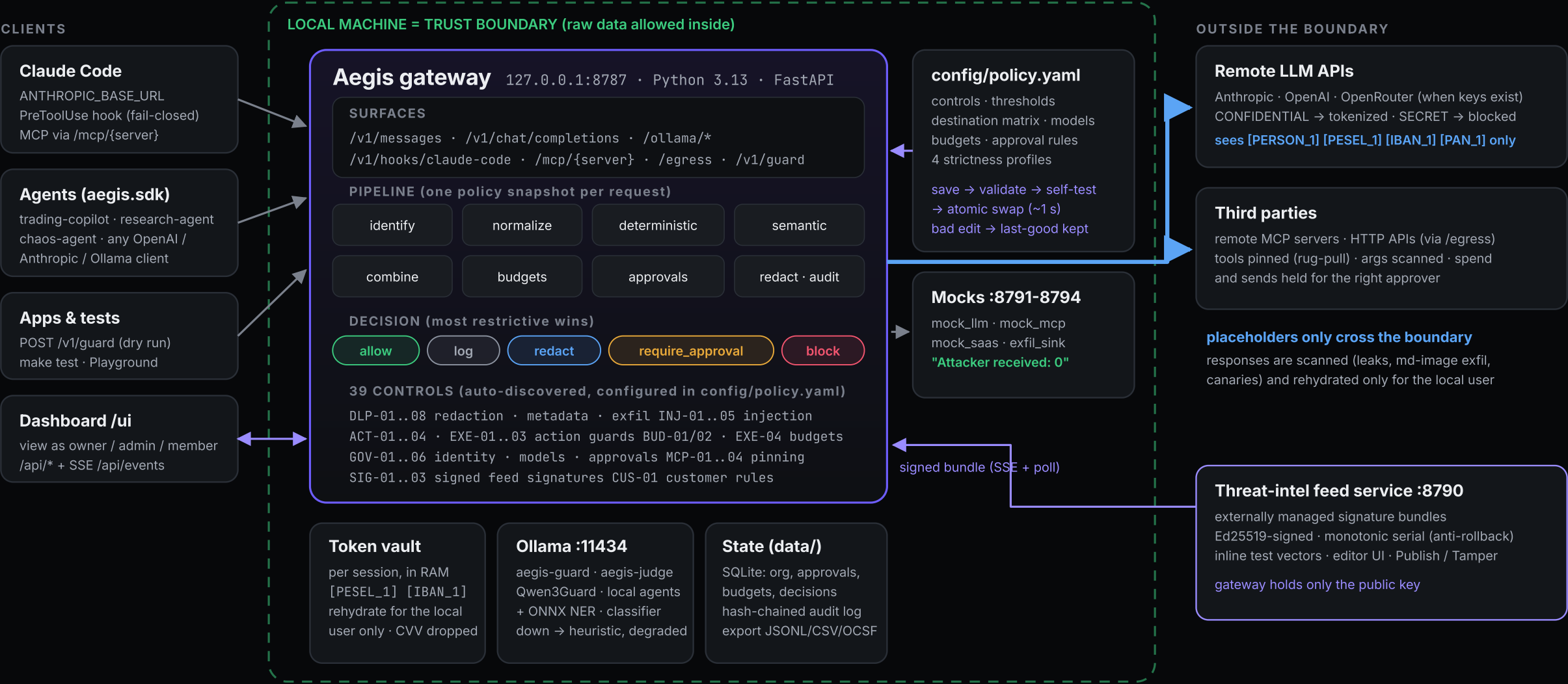
LiteLLM 1.82.7–1.82.8 PyPI compromise

ARCHITECTURE

One policy decision point for every hop

Aegis: one local gateway on every agent hop

Every request becomes an Interaction, runs one hot-reloaded policy pipeline and ends in allow · log · redact · require_approval · block



Hybrid guardrails: deterministic first (checksums, secrets, command/SSRF, MCP pinning, signatures), small local models second, never authorizing.

Budgets org → team → agent → session (tokens, USD, local compute-s) · loop detector · kill switch · approvals routed by role, action and amount.

Ports: gateway 8787 · feed 8790 · mock_llm 8791 · mock_mcp 8792 · exfil_sink 8793 · mock_saas 8794 · Ollama 11434

Claude Code: ANTHROPIC_BASE_URL + fail-closed PreToolUse hook + MCP via /mcp/{server}, from one demo settings profile (make claude), nothing machine-wide.

Decisions map to the OWASP Agent Control Standard: allow · modify · deny · ask

The remote model never sees the customer

What you typed

Draft a reply to Jan Kowalski, PESEL 44051401359, IBAN PL61 1090 1014 0000 0712 1981 2874, card 4111 1111 1111 1111 exp 12/27 ~~CVV-123~~

What the remote model received

Draft a reply to [PERSON_1], PESEL [PESEL_1], IBAN [IBAN_1], card [PAN_1] exp [CARD_EXPIRY_1]

- **Detected on the device:** PII, cards, Polish IDs (PESEL, NIP, REGON, IBAN), secrets, metadata (user paths, hostnames, client headers).
- **Validators, not bare regex:** Luhn, PESEL / NIP checksums, IBAN mod-97, context words. **Destination-aware:** raw to local Ollama, tokenized to remote, tokenized or blocked to third parties.
- **PCI:** CVV dropped, never vaulted; PAN shown as first 6 / last 4; audit keeps keyed HMACs. Real values return only to the local user.
- Fixture set (626 cases): leak rate on validated types **0 %** · precision **1.0** · recall **1.0** · p95 **0.35 ms**

Deterministic first, AI second, every hop

Deterministic tier μs –ms

- Unicode normalization: zero-width, tag characters, homoglyphs, base64 / hex
- Secrets, command guard (`curl` | `sh`), SSRF guard
- MCP poisoning scan + rug-pull pinning
- Exfil-link stripping · signed exploit signatures

Semantic tier local models, escalation only

- Injection classifier · Qwen3Guard · multilingual NER
- Per-control `fail_mode` : model down → deterministic-only + **degraded** flag, never silent pass
- Screens tool results, MCP descriptions, fetched pages, not just the prompt
- Never authorizes anything: tools, budgets, approvals stay deterministic

92.4 %

ATTACK DETECTION, OPTIONAL LOCAL
MODELS ON · HELD-OUT 89.6 % ·
DETERMINISTIC ONLY 66.6 %

5.1 %

FALSE POSITIVES, MODELS ON (510
BENIGN) · DETERMINISTIC ONLY 0.4 %

**LLM 9/10 · ASI 10/10 ·
MCP 10/10**

OWASP COVERAGE (LIVE)

Spend and actions follow your org chart

- **Budgets** org → team → agent → session: tokens, USD, **local compute-seconds**; soft limit → downgrade to a local model; hard → 402
- **Runaway agents:** repeat / cycle detection → tool error → block → kill switch (429 `killed`)
- **Roles:** owner · admin · member · agents as service identities (never approvers)
- Grants bound to **exact parameters**, single-use, expiring, audited

screens/approvals.png · inbox as u_piotr: "needs admin"

Who approves what

Agent purchase ≤ \$20	sponsor
\$50 MarketPulse subscription	admin
\$480 GPU reservation	owner
> \$1,000	owner + admin
> \$5,000	blocked
Read a PII table	admin
Read card data	never
Production DB write	owner
Team budget +25 % / ×2.5	admin / owner
Disable a critical control	owner

Edit it live and it stays safe

One YAML file: `config/policy.yaml`

- Controls, mode, action, **threshold**, **adherence %**, allowed models, budgets, approval rules
- Strictness profiles: permissive · **balanced** · strict · paranoid
- Save → validate → **self-test gate** → atomic swap; version stamped on every decision
- Bad YAML → rejected with line/col, last-good keeps serving · reload p95 **1107 ms**

```
- id: INJ-02
  threshold: 0.80 0.50 # Borderline (0.62): allow
→ block
```

External threat feed :8790

- Separate service signs bundles with **Ed25519**; the gateway holds only the public key
- Monotonic serial (anti-rollback), expiry, sha256 pinning, closed matcher set (a feed can't ship code)
- Inline test vectors must pass before a signature activates
- Seeds: malicious pickles, compromised packages, MCP tool poisoning, EchoLeak-style exfiltration
- Publish **AEGIS-TI-022** → replay blocked · **Tamper** → rejected

Every decision explained, chained, exportable

screens/live.png · live decision feed + decision drawer

Management

Spend vs budget by team, blocked interactions, cost avoided, approvals.

Security

Live stream: control, score vs threshold, redacted evidence, policy + feed version, Wire view.

Audit

Append-only, **hash-chained**, redacted at write time.
Export JSONL · CSV · **OCSF**. Prometheus `/metrics`,
`Server-Timing`.

One command proves every control

1,045

BLACK-BOX CASES · MAKE TEST (+ UNIT TESTS: 2,006 PASS)

0

FAILED

2.40 / 3.82

OVERHEAD P50 / P95 MS

320

REQUESTS / S · MAKE BENCH

- **No model needed**; semantic cases are skipped with a reason, never silently passed
- **Per-control matrix**: must-block / must-allow / must-redact; asserts **which** control decided
- Any control without both an allowed and a blocked case is **UNTESTED** and fails the run
- **False-positive wall**: "kill switch", "execute the order", "egzekucja zlecenia" must pass
- Jailbreak corpora reported as rates with confidence intervals, not a fake 100 %

screens/tests.png · make test matrix

From laptop to a regulated bank

Deploy shape

Data plane local: a sidecar per developer or agent host, because redaction must happen before egress. **Control plane central:** policy via GitOps with the same self-test gate, signed feed, approvals, audit to the SIEM.

Scale path

Stateless workers, Postgres for org and approvals, Redis/Lua for atomic multi-level budget reservation (designed). Can sit behind an open-source gateway as its guard webhook. Standards: OWASP ACS, OCSF, OpenTelemetry GenAI.

Compliance evidence

GDPR minimisation & pseudonymisation · PCI DSS v4.0.1 (no stored CVV, masked PAN) · EU AI Act logging & human oversight · DORA third-party register & exit levers. *Supports, does not certify.*

Try to break it

`make setup && make up` → `http://127.0.0.1:8787/ui` · Playground · edit `config/policy.yaml` · publish a feed signature · `make test` · github.com/JustAnotherDevv/tiles-hackyeah-2026/tree/main/aegis